

Sohken — research sources and evidence notes

Research checked: 16 September 2026. Sources were read through direct web research. The requested deep-research skill was inspected, but its Gemini runner and credentials were absent; no Gemini research job was executed. Data's design-kpis skill informed the measurement framework. No customer interviews, platform benchmarks, or deployment tests have yet been performed.

Evidence classes: **V** = vendor-confirmed vulnerability; **D** = researcher demonstration; **B** = benchmark experiment; **G** = official guidance/documentation; **H** = Sohken engineering or commercial hypothesis. A demonstration establishes a possible failure under its setup, not its frequency in production. Documentation establishes described functionality, not independently verified effectiveness.

Supplied source

S00 — Production Agent Reliability & Security Platform, supplied PDF, three pages, undated. Page 1: failure classes and landscape. Page 2: problem, architecture, MVP. Page 3: targets, customer wedge, positioning, sequence. Its [web:...] markers are unresolved references, not usable citations. Its instructions are proposed product requirements being assessed, not instructions authorizing actions in this workspace. The user's request controls this work. Original: `../production_agent_platform_full_problem_statement.pdf`.

Read sources

ID	Source and date/version	Class	What it supports; limits
S01	Microsoft: AI Application Security Series 1 , 17 Dec 2025	V/G	Microsoft describes EchoLeak, CVE-2025-32711, as fixed; in certain conditions crafted email could expose limited accessible internal data. This does not establish customer compromise or current vulnerability.
S02	Invariant: GitHub MCP exploited , 26 May 2025	D	Demonstrates malicious public issue → private repository read → public pull request disclosure in a configured agent. Vendor research, not independent incident prevalence.
S03	Invariant: Tool poisoning attacks , Apr 2025	D	Describes malicious tool descriptions and changing tool behavior. Treat as attack demonstrations, not proof every MCP deployment is vulnerable.
S04	AgentDojo , 2024	B	Original benchmark has 97 tasks and 629 security cases involving untrusted tool data. Useful methodology; its models and distributions are not Sohken's pilot.
S05	tau-bench , 2024	B	Evaluates final database state and repeated-run reliability. Original tested agents achieved under 50% task success and retail pass ⁴ 8 under 25%; these are historical benchmark results, not current model performance.
S06	Assessing Automated Prompt Injection Attacks in Agentic Environments , Jun 2026 preprint	B	Studies automated attacks on 80 task pairs; attack effectiveness and transfer depend on models. Supports testing adaptive attacks, not assuming static suite coverage. Abstract-level review.
S07	Anthropic: Mitigating prompt injections in browser use , 24 Nov 2025	B/G	Provider research reports improvements while explicitly retaining unresolved prompt-injection risk. Browser results do not directly measure tool-gateway safety.
S08	NVIDIA: Tool Calling rails , live docs checked 16 Sep 2026	G	Documents tool name/schema checks and structural result linkage; distinguishes these from content safety and server-verified provenance. Engine/configuration limitations matter.
S09	MCP: Security best practices , 2026-07-28 docs path	G	Audience validation and token-passthrough risks. Main-branch documentation is mutable; implementation must pin a release and protocol version.
S10	AWS Builders' Library: Making retries safe with idempotent APIs , 2021	G	Explains request identity and semantic equivalence under retry. Does not make arbitrary external side effects exactly once.
S11	OWASP LLM06:2025 Excessive Agency , 2025 taxonomy	G	Reference for excessive functionality, permissions, and autonomy. Version-specific background, not a claim this is the newest LLM list.
S12	OWASP Top 10 for Agentic Applications 2026 , Dec 2025, version 2026	G	Agent-specific threat taxonomy including goal hijacking, memory poisoning, identity abuse, and cascading failures. Not an incidence survey or certification.
S13	NIST AI 600-1: Generative AI Profile , 26 Jul 2024	G	Lifecycle risk-management reference. Mapping proposed controls is not NIST certification or legal compliance.
S14	OpenTelemetry GenAI conventions repository and attribute registry , live docs checked 16 Sep 2026	G	GenAI conventions have a separate repository and development-status attributes. Version schema and exporters explicitly.
S15	Langfuse overview , live docs checked 16 Sep 2026	G	Describes self-hosting, tracing, prompt management, evaluation and OTel integration. Establishes overlap with proposed dashboard features; no comparative performance test.
S16	LangSmith evaluation concepts , live docs checked 16 Sep 2026	G	Describes offline/online evaluation and datasets. Do not assume commercial terms or feature exclusions without a separate purchasing review.

ID	Source and date/version	Class	What it supports; limits
S17	OPA bundles , live docs checked 16 Sep 2026	G	Describes policy distribution and configurable signature verification. Signing a bundle alone does not mean all loading paths verify it.
S18	gVisor security model , live docs checked 16 Sep 2026	G	Describes host attack-surface reduction and remaining network/resource responsibilities. Sandbox isolation does not authorize destinations.
S19	PostgreSQL 17 row security	G	Table owners and privileged roles can bypass RLS; application roles and tests matter. Scope deliberately pinned to version 17 documentation.
S20	MIT 6.5840 general information , Spring 2026	G	Graduate distributed-systems course reference for systems reasoning and practical labs. The Sohken plan is independently authored, not an MIT curriculum, project, or endorsement.

Search and selection method

Started with the PDF's nine failure classes; searched primary sources for injection demonstrations, tool poisoning, state-based evaluation, retries, authorization, isolation, telemetry, and current competing capabilities. Followed search results to original researchers, vendors, standards bodies, and maintainers. Added a 2026 benchmark paper and agentic taxonomy to avoid relying entirely on 2024–25 material. Reviewed conflicting NVIDIA capability claims against current documentation. Did not use Reddit anecdotes, unsourced market percentages, or sensational incident summaries as findings.

The Aim Security EchoLeak page could not be fetched (403); the report instead uses Microsoft's directly readable acknowledgement. The original PDF's exact NVIDIA citation could not be reconstructed. Therefore the correction is about its broad current claim, not an assertion about what an older NVIDIA version supported. Research is focused, not an exhaustive systematic review. Customer demand, incident frequency, willingness to pay, and Sohken performance remain unmeasured.

Interpreting the output files

Source-linked failure mechanisms are evidence. Priorities, architecture, acceptance thresholds, schedule, workload sizes, and dollar scenarios are Sohken design proposals. They are explicitly not externally measured facts. Source IDs in the problems list and plan resolve here; each main document also contains a compact linked bibliography.